



Developer Workbook for Delta

4/13/26

Delta IT DIS Team

Report Overview

Report Summary

On 2026413, a source code review was performed over the DMP_ETL code base. 6 files, 1,233 LOC (Executable) were scanned. A total of 0 issues were uncovered during the analysis. This report provides a comprehensive description of all the types of issues found in this project. Specific examples and source code are provided for each issue type.

Issues by Folder

Critical	0
High	0
Medium	0
Low	0

Code Base Summary

Number of Files: 6
Total Lines of Code: 1233

Scan Information

Scan time: 00:48
SCA Engine version: 25.2.0.0116
Warnings: 2 occurred during scan

Results Signature Information

Results Certification Valid
Details:
Results Signature:

SCA Analysis Results has Valid signature

Rules Signature:

There were no custom rules used in this scan

Issue Summary

Overall number of results

The scan found 0 issues.

Issues by Category

Refined by: [analysis]:not an issue

Issues by Category

Refined by: [fortify priority order]:critical [analysis]:!"not an issue"

Issues by Category

Refined by: [fortify priority order]:high [analysis]:!"not an issue"

Issues by Category

Refined by: [fortify priority order]:medium

Issues by Category

Refined by: [fortify priority order]:low

Results Outline
Critical Issues List by Category
High Issues List by Category:
Medium Issues List by Category
Low Issues List by Category

Appendix

Rulepacks

Valid Rulepacks:

Name: Fortify Secure Coding Rules, Community, Cloud

Version: 2026.1.0.0006

ID: 686C4B2F-0321-4025-B9F4-6E26094B4746

SKU: RUL13242

Name: Fortify Secure Coding Rules, Community, Universal

Version: 2026.1.0.0006

ID: 97b8b0e6-618b-47cf-a7fb-8636faea6b75

SKU: RUL13240

Name: Fortify Secure Coding Rules, Core, Cloud

Version: 2026.1.0.0006

ID: BDACC98E-569C-4ECC-92AA-8DD890DF1287

SKU: RUL13249

Name: Fortify Secure Coding Rules, Core, Python

Version: 2026.1.0.0006

ID: FD15CBE4-E059-4CBB-914E-546BDCEB422B

SKU: RUL13083

Name: Fortify Secure Coding Rules, Core, Universal

Version: 2026.1.0.0006

ID: 88D39959-D322-499A-87F3-BC9E1193B07A

SKU: RUL13241

Name: Fortify Secure Coding Rules, Extended, Configuration

Version: 2026.1.0.0006

ID: CD6959FC-0C37-45BE-9637-BAA43C3A4D56

SKU: RUL13005

Name: Fortify Secure Coding Rules, Extended, Content

Version: 2026.1.0.0006

ID: 9C48678C-09B6-474D-B86D-97EE94D38F17

SKU: RUL13067

External Metadata:

Version: 2026.1.0.0006

Name: AKS

ID: E244A68A-528E-4ADA-A935-B0EC0BD7109F

The CIS Azure Kubernetes Service (AKS) Benchmark v1.3.0 from the Center for Internet Security (CIS) provides prescriptive guidance for establishing a secure baseline configuration for Azure Kubernetes Service.

Name: CIS Amazon Web Services 2.0.0

ID: F7D454BE-9612-4D3B-9A11-08886232FB2D

The CIS Amazon Web Services Foundations Benchmark v2.0.0 from the Center for Internet Security (CIS) provides prescriptive

guidance for establishing a secure baseline configuration for Amazon Web Services.

Name: CIS Google Cloud 2.0.0

ID: 0295D43A-6909-4EEC-B939-1244B2905862

The CIS Google Cloud Platform Foundation Benchmark v2.0.0 from the Center for Internet Security (CIS) provides prescriptive guidance for establishing a secure baseline configuration for Google Cloud.

Name: CIS Kubernetes 1.7.1

ID: F5200B7A-129F-482B-BF6C-AB1EBD21553E

The CIS Kubernetes Benchmark v1.7.1 from the Center for Internet Security (CIS) provides prescriptive guidance for establishing a secure baseline configuration for Kubernetes v1.25.

Name: CIS Microsoft Azure 2.0.0

ID: E57A2F1A-B80F-4DA1-99A7-68BECDC54891

The CIS Microsoft Azure Foundations Benchmark from the Center for Internet Security (CIS) provides prescriptive guidance for establishing a secure baseline configuration for Microsoft Azure.

Name: CWE

ID: 3ADB9EE4-5761-4289-8BD3-CBFCC593EBBC

The Common Weakness Enumeration (CWE), co-sponsored and maintained by MITRE, is international in scope and free for public use. CWE provides a unified, measurable set of software weaknesses that is enabling more effective discussion, description, selection, and use of software security tools and services that can find these weaknesses in source code and operational systems as well as better understanding and management of software weaknesses related to architecture and design.

Name: CWE Top 25 2023

ID: D0A4A1E9-36C4-4E47-9F0F-597D22E6DC66

The 2023 CWE Top 25 Most Dangerous Software Errors lists the most widespread and critical weaknesses that can lead to serious vulnerabilities in software (as demonstrated by the National Vulnerability Database). These weaknesses occur frequently, are often easy to find, and easy to exploit. They are dangerous because they will frequently enable attackers to completely take over the software, steal data, or prevent the software from working at all. The list is the result of heuristic formula that the CWE Team used with a data-driven approach that leveraged the Common Vulnerabilities and Exposure (CVE), National Vulnerability Database (NVD), and Common Vulnerability Scoring System (CVSS). Due to the hierarchical nature of the CWE taxonomy, Fortify considers all CWE IDs which are children of a Top 25 entry, as included within the context of the entry due to the "CHILD-OF" relationship within the hierarchy. Exercise caution if using only this Top 25 list to prioritize auditing efforts because the software under analysis might not align with the assumptions of the heuristic used to define the Top 25. For example, many of these weaknesses are related to C-like languages and the software under analysis might not be within the C-family of languages - thus, many CWEs would not be in scope.

Name: CWE Top 25 2024

ID: 4F1BC072-B396-4F7C-93B1-00550056742C

The 2024 CWE Top 25 Most Dangerous Software Errors lists the most widespread and critical weaknesses that can lead to serious vulnerabilities in software (as demonstrated by the National Vulnerability Database). These weaknesses occur frequently, are often easy to find, and easy to exploit. They are dangerous because they will frequently enable attackers to completely take over the software, steal data, or prevent the software from working at all. The list is the result of heuristic formula that the CWE Team used with a data-driven approach that leveraged the Common Vulnerabilities and Exposure (CVE), National Vulnerability Database (NVD), and Common Vulnerability Scoring System (CVSS). Due to the hierarchical nature of the CWE taxonomy, Fortify considers all CWE IDs which are children of a Top 25 entry, as included within the context of the entry due to the "CHILD-OF" relationship within the hierarchy. Exercise caution if using only this Top 25 list to prioritize auditing efforts because the software under analysis might not align with the assumptions of the heuristic used to define the Top 25. For example, many of these weaknesses are related to C-like languages and the software under analysis might not be within the C-family of languages - thus, many CWEs would not be in scope.

Name: CWE Top 25 2025

ID: 32A89668-8020-4CF6-95D6-BF37C9C3988D

The 2025 CWE Top 25 Most Dangerous Software Errors lists the most widespread and critical weaknesses that can lead to serious vulnerabilities in software (as demonstrated by the National Vulnerability Database). These weaknesses occur frequently, are often easy to find, and easy to exploit. They are dangerous because they will frequently enable attackers to completely take over the software, steal data, or prevent the software from working at all. The list is the result of heuristic formula that the CWE Team used with a data-driven approach that leveraged the Common Vulnerabilities and Exposure (CVE), National Vulnerability Database (NVD), and Common Vulnerability Scoring System (CVSS). Due to the hierarchical nature of the CWE taxonomy, Fortify considers all CWE IDs which are children of a Top 25 entry, as included within the context of the entry due to the "CHILD-OF" relationship within the hierarchy. Exercise caution if using only this Top 25 list to prioritize auditing efforts because the software under analysis might not align with the assumptions of the heuristic used to define the Top 25. For example, many of these weaknesses are related to C-like languages and the software under analysis might not be within the C-family of languages - thus, many CWEs would not be in scope.

Name: DISA CCI 2

ID: 7F037130-41E5-40F0-B653-7819A4B3E241

The purpose of a Defense Information Systems Agency (DISA) Control Correlation Identifier (CCI) is to provide a standard identifier for policy based requirements which connect high-level policy expressions and low-level technical implementations. Associated with each CCI is a description for each of the singular, actionable, statements compromising an information assurance (IA) control or IA best practice. Using CCI allows high-level policy framework security requirements to be decomposed and explicitly associated with low-level implementations, thus enabling the assessment of related compliance assessment results spanning heterogeneous technologies. The current IA controls and best practices associated with each CCI, that are specified in NIST SP 800-53 Revision 4, can be viewed using the DISA STIG Viewer.

The following table summarizes the number of issues identified across the different CCIs broken down by Fortify Priority Order. The status of a CCI is considered "In Place" when there are no issues reported for a given CCI.

If the project is missing a Fortify Static Code Analyzer (SCA) scan, or the scan contains findings that have not been fixed, hidden or suppressed, CCI-003187 is not considered "In Place". Similarly, if the project is missing a Fortify WebInspect scan, or the scan contains any critical findings, CCI-000366 and CCI-000256 are not considered "In Place".

Name: EKS

ID: A5FCC3D2-3F76-49A6-9978-545D7E85EC55

The CIS Amazon Elastic Kubernetes Service (EKS) Benchmark v1.3.0 from the Center for Internet Security (CIS) provides prescriptive guidance for establishing a secure baseline configuration for Amazon Elastic Kubernetes Service.

Name: FISMA

ID: B40F9EE0-3824-4879-B9FE-7A789C89307C

The Federal Information Processing Standard (FIPS) 200 document is part of the official series of publications, issued by the National Institute of Standards and Technology (NIST), relating to standards and guidelines adopted and promulgated under the provisions of the Federal Information Security Management Act (FISMA). Specifically, FIPS Publication 200 specifies the "Minimum Security Requirements for Federal Information and Information Systems."

Name: GDPR

ID: 771C470C-9274-4580-8556-C12F5E4BEC51

The EU General Data Protection Regulation (GDPR) replaces the Data Protection Directive 95/46/EC and was designed to harmonize data privacy laws across Europe, to protect and empower all EU citizens data privacy and to reshape the way organizations across the region approach data privacy. Going into effect on May 25, 2018, GDPR provides a framework for organizations on how to handle personal data. According to GDPR regulation personal data "means any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or

to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person." GDPR articles that pertain to application security and require businesses to protect personal data during design and development of its product and services are:

- Article 25, Data protection by design and by default - which requires "The controller shall implement appropriate technical and organisational measures for ensuring that, by default, only personal data which are necessary for each specific purpose of the processing are processed."

- Article 32, Security of processing - which requires businesses to protect its systems and applications "from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data". This report may be used by organizations as a framework to help identify and protect personal data as it relates to application security.

Name: GKE

ID: 800E87DB-CC72-48B1-8AB1-5C4D30B964F0

The CIS Google Kubernetes Engine (GKE) Benchmark v1.4.0 from the Center for Internet Security (CIS) provides prescriptive guidance for establishing a secure baseline configuration for Google Kubernetes Engine Service.

Name: MISRA C 2012

ID: 555A3A66-A0E1-47AF-910C-3F19A6FB2506

Now in its third edition, the Motor Industry Software Reliability Association (MISRA) C Guidelines describe a subset of the C programming language in which there is reduced risk of introducing mistakes in critical systems. While the MISRA C Guidelines focus upon safety-related software development, a subset of the rules reflects security properties. Fortify interprets the MISRA C Guidelines under the context of security and provides correlation of security vulnerability categories to the rules defined by MISRA. Fortify provides these security focused detection mechanisms with the standard rulepacks, however, further support of the MISRA C Guidelines related to safety can be added through the use of custom rules. The results in this report can assist in the creation of a compliance matrix for MISRA.

Name: MISRA C 2023

ID: 2025F738-3EC7-4226-B477-B002C3FDE9C0

MISRA is a "collaboration between manufacturers, component suppliers and engineering consultancies which seeks to promote best practice in developing safety and security-related electronic systems and other software-intensive applications." The MISRA C 2023 Guidelines "describe a subset of the C programming language in which the opportunity to make mistakes is either removed or reduced."

In practice, the MISRA C 2023 Guidelines provide an in-depth set of directives and rules to use for the identification of safety or security related coding practices. Fortify interprets the MISRA C 2023 Guidelines under the context of security and provides correlation of security vulnerability categories to the directives and rules defined by MISRA. Fortify provides these security focused detection mechanisms with the standard rulepacks, however, further support of the MISRA C 2023 Guidelines related to safety can be added through the use of custom rules. The results in this report can assist in the creation of a compliance matrix for MISRA.

Name: MISRA C++ 2008

ID: 5D4B75A1-FC91-4B4B-BD4D-C81BBE9604FA

The Motor Industry Software Reliability Association (MISRA) C++ Guidelines describe a subset of the C++ programming language in which there is reduced risk of introducing mistakes in critical systems. While the MISRA C++ Guidelines focus upon safety-related software development, a subset of the rules reflects security properties. Fortify interprets the MISRA C++ Guidelines under the context of security and provides correlation of security vulnerability categories to the rules defined by MISRA. Fortify provides these security focused detection mechanisms with the standard rulepacks, however, further support of the MISRA C++ Guidelines related to safety can be added through the use of custom rules. The results in this report can assist in the creation of a compliance matrix for MISRA.

Name: MISRA C++ 2023

ID: 71A11E04-5CD7-4FEE-8BBF-C3ECB8581755

MISRA is a "collaboration between manufacturers, component suppliers and engineering consultancies which seeks to promote best practice in developing safety and security-related electronic systems and other software-intensive applications." The MISRA C++ 2023 Guidelines "describe a subset of the C++ programming language in which the opportunity to make mistakes is either removed or reduced." MISRA C++ 2023 represents a combination of updated guidance based on MISRA C++ 2008 and guidance taken from the AUTOSAR C++14 guidelines.

 In practice, the MISRA C++ 2023 Guidelines provide an in-depth set of directives and rules to use for the identification of safety or security related coding practices. Fortify interprets the MISRA C++ 2023 Guidelines under the context of security and provides correlation of security vulnerability categories to the directives and rules defined by MISRA. Fortify provides these security focused detection mechanisms with the standard rulepacks, however, further support of the MISRA C++ 2023 Guidelines related to safety can be added through the use of custom rules. The results in this report can assist in the creation of a compliance matrix for MISRA.

Name: NIST SP 800-53 Rev.4

ID: 1114583B-EA24-45BE-B7F8-B61201BACDD0

NIST Special Publication 800-53 Revision 4 provides a list of security and privacy controls designed to protect federal organizations and information systems from security threats. The following table summarizes the number of issues identified across the different controls and broken down by Fortify Priority Order.

Name: NIST SP 800-53 Rev.5

ID: 32434089-54F3-49F8-93F8-688B6B2FE8ED

NIST Special Publication 800-53 Revision 5 provides a list of security and privacy controls designed to protect federal organizations and information systems from security threats. The following table summarizes the number of issues identified across the different controls and broken down by Fortify Priority Order.

Name: OWASP API Top 10 2023

ID: 5240B1AE-EB36-4DBD-9FC3-34BC60F05EE0

The OWASP API Top 10 2023 provides a list of the top security risks affecting APIs in 2023. It aims to raise awareness around API security weaknesses and to educate those involved in API development and maintenance, such as developers, designers, architects, managers and/or organizations in general who need to secure Web APIs. The OWASP API Top 10 focuses on weaknesses affecting Web APIs and it is not intended to be used only by itself, instead it is intended to be used in combination with other standards and best practices in order to thoroughly capture all relevant risks. For example: it should be used in combination with the OWASP Top 10 in order to identify issues related to input validation such as injections.

Name: OWASP ASVS 4.0

ID: 28083E33-760F-4A1A-AADA-738CC60082AD

The OWASP Application Security Verification Standard establishes a framework of security requirements and controls that focus on functional and non-functional security controls for the software development lifecycle based upon a community-driven effort. OWASP ASVS identifies several application security verification levels, with each level increasing depth:

ASVS Level 1 (L1): for low assurance levels and is completely penetration testable.

ASVS Level 2 (L2): for applications that contain sensitive data, which requires protection, and is the recommended level for most apps.

ASVS Level 3 (L3): for the most critical applications - applications that perform high value transactions, contain sensitive medical data, or any application that requires the highest level of trust.

Name: OWASP ASVS 5.0

ID: 818545B3-8FFD-4FCF-A4A6-2E0C38028787

The OWASP Application Security Verification Standard establishes a collection of security requirements for web applications and services that have a "demonstrable impact on security". OWASP ASVS is a community-driven effort, created and maintained to

collectively advance the state of application security. OWASP ASVS defines three security verification levels in order to help prioritize effort in applying the standard to a given application:

- Level 1 (L1): Minimum requirements to consider when securing an application, a "critical starting point containing first-layer of defence requirements."
- Level 2 (L2): Typical requirements to consider when securing an application, including "less common attacks or more complicated protections against common attacks."
- Level 3 (L3): Advanced requirements to consider when securing an application, for "applications looking to demonstrate the highest levels of security."

The correlation of the Seven Pernicious Kingdoms (7pk) taxonomy to OWASP ASVS 5.0 is done irrespective of "ASVS Level" as 7pk represents software weakness over a broad range of realization from high level vulnerabilities found by dynamic analysis (more aligned with ASVS Level 1) to a very granular level of code smells found by static analysis (more aligned with ASVS Level 3).

Name: OWASP LLM Top 10 2025
ID: CDB66BE7-1C47-4FAA-877F-C2A6590CF98B

The OWASP Top 10 for Large Language Model Applications of 2025 highlight and address the top security issues specific to AI models and applications of 2025. It aims to raise awareness and build a foundation for securing the utilization of a LLM. The OWASP LLM Top 10 provide a structured framework for understanding generative AI's most critical security risks. It details both the top LLM vulnerabilities, and their respective mitigations for developing and securing generative AI and large language model applications across the development, deployment and management lifecycle. The following table summarizes the number of issues identified across the different LLMIDs broken down by Fortify Priority Order. The status of a LLMID is considered "Addressed" when there are no issues reported for a given LLMID.

Name: OWASP MASVS 2.0
ID: 89717E5C-2EC1-4D41-9A7C-6BCD91C8E9AA

The OWASP Mobile Application Security Verification Standard (MASVS) 2.0 provides a powerful awareness document for mobile application security. The OWASP MASVS represents a broad consensus about what the most critical mobile application security flaws are. MASVS is intended to be used by architects, and developers, aiming to develop secure mobile applications. Testers evaluating mobile applications for completeness of security control coverage, and mitigation of risks can also use MASVS as a guide in addition to the OWASP Mobile Security Testing Guide (MASTG). Mobile apps often interact with diverse systems such as backend servers, third-party APIs, Bluetooth devices, cars, and IoT devices, each introducing its own set of security risks. Consequently, these risks must be considered during the mobile app's security design and threat modeling process. For instance, when engaging with a backend server, it is essential to employ the OWASP Application Security Verification Standard (ASVS), in addition to the OWASP MASVS, to ensure the server meets the required security standards.

Name: OWASP Mobile 2014
ID: EEE3F9E7-28D6-4456-8761-3DA56C36F4EE

The OWASP Mobile Top 10 Risks 2014 provides a powerful awareness document for mobile application security. The OWASP Mobile Top 10 represents a broad consensus about what the most critical mobile application security flaws are. Project members include a variety of security experts from around the world who have shared their expertise to produce this list.

Name: OWASP Mobile Top 10 2024
ID: AFD1485A-AAEC-4DE5-A9E2-F1EB15EFD848

The OWASP Mobile Top 10 Risks 2024 provides a list of the top 10 risks affecting mobile applications in 2024. It represents a broad consensus on what the most critical mobile application security vulnerabilities are in 2024. The OWASP Mobile Top 10 focuses on weaknesses affecting mobile applications and it is not intended to be used only by itself. Instead it is intended to be used in combination with other standards and best practices in order to thoroughly capture all relevant risks. For example, it should be used in combination with the OWASP API Top 10 in order to identify issues related to requests sent from the mobile application to the server.

Name: OWASP Top 10 2017

ID: 3C6ECB67-BBD9-4259-A8DB-B49328927248

The OWASP Top Ten 2017 provides a powerful awareness document for web application security focused on informing the community about the consequences of the most common and most important web application security weaknesses. The OWASP Top Ten represents a broad agreement about what the most critical web application security flaws are with consensus being drawn from data collection and survey results. Project members include a variety of security experts from around the world who have shared their expertise to produce this list.

Name: OWASP Top 10 2021

ID: 1887A283-3C0D-453C-AD10-0B451EAF096D0

The OWASP Top 10 2021 provides a powerful awareness document for web application security focused on informing the community about the consequences of the most common and most important web application security weaknesses. The OWASP Top 10 represents a broad agreement about what the most critical web application security flaws are with consensus drawn from data collection and survey results. Project members include a variety of security experts from around the world who have shared their expertise to produce this list.

Name: OWASP Top 10 2025

ID: 5593E81B-55BF-42DA-A222-0E948504AE80

The OWASP Top 10 2025 provides a powerful awareness document for web application security focused on informing the community about the consequences of the most common and most important web application security weaknesses. The OWASP Top 10 represents a broad agreement about what the most critical web application security flaws are with consensus drawn from data collection and survey results. Project members include a variety of security experts from around the world who have shared their expertise to produce this list.

Name: PCI 3.2.1

ID: EADE255F-6561-4EFE-AD31-2914F6BFA329

The following is a summary of the application security portions of Payment Card Industry (PCI) Data Security Standard (DSS) v3.2.1. Fortify tests for 31 application security related requirements across sections 1, 2, 3, 4, 6, 7, 8, and 10 of PCI DSS and reports whether each requirement is In Place or Not In Place to indicate whether requirements are satisfied or not. This report is intended to measure the level of adherence the specific application(s) possess when compared to PCI DSS 3.2.1 compliance and is not intended to serve as a comprehensive Report on Compliance (ROC). The information contained in this report is targeted at project managers, security auditors, and compliance auditors.

Name: PCI 4.0

ID: A2937951-C21A-4CFF-9A73-220C67EBDD8C

The following is a summary of the application security portions of Payment Card Industry (PCI) Data Security Standard (DSS) v4.0. Fortify tests for 39 application security related requirements across sections 1, 2, 3, 4, 5, 6, 7, 8, 10 and 12 of PCI DSS and reports whether each requirement is In Place or Not In Place to indicate whether requirements are satisfied or not. This report is intended to measure the level of adherence the specific application(s) possess when compared to PCI DSS 4.0 compliance and is not intended to serve as a comprehensive Report on Compliance (ROC). The information contained in this report is targeted at project managers, security auditors, and compliance auditors.

Name: PCI 4.0.1

ID: 49304FFB-55B9-40EE-942E-8242C227F501

The following is a summary of the application security portions of Payment Card Industry (PCI) Data Security Standard (DSS) v4.0.1 Fortify tests for 40 application security related requirements across sections 1, 2, 3, 4, 5, 6, 7, 8, 10 and 12 of PCI DSS and reports whether each requirement is In Place or Not In Place to indicate whether requirements are satisfied or not. This report is intended to measure the level of adherence the specific application(s) possess when compared to PCI DSS 4.0.1 compliance and is not intended to serve as a comprehensive Report on Compliance (ROC). The information contained in this report is targeted at project managers, security auditors, and compliance auditors.

Name: PCI SSF 1.0

ID: 0F551543-AF0E-4334-BEDF-1DDCD5F4BF74

The following is a summary of the application security portions of the Secure Software Requirements and Assessment Procedures defined in the Payment Card Industry (PCI) Software Security Framework (SSF) v1.0. Fortify tests for 23 application security related control objectives across Control Objective sections 2, 3, 4, 5, 6, 7, 8, and A.2 of PCI SSF and reports whether each control objective is In Place or Not In Place to indicate whether requirements are satisfied or not. This report is intended to measure the level of adherence the specific application(s) possess when compared to PCI SSF 1.0 compliance and is not intended to serve as a comprehensive Report on Compliance (ROC). The information contained in this report is targeted at project managers, security auditors, and compliance auditors.

Name: PCI SSF 1.1

ID: 601EA2F3-5EDC-411C-818C-10DC5B29467D

The following is a summary of the application security portions of the Secure Software Requirements and Assessment Procedures defined in the Payment Card Industry (PCI) Software Security Framework (SSF) v1.1. Fortify tests for 31 application security related control objectives across Control Objective sections 2, 3, 4, 5, 6, 7, 8, A.2, B.2, and B.3 of PCI SSF and reports whether each control objective is In Place or Not In Place to indicate whether requirements are satisfied or not. This report is intended to measure the level of adherence the specific application(s) possess when compared to PCI SSF 1.1 compliance and is not intended to serve as a comprehensive Report on Compliance (ROC). The information contained in this report is targeted at project managers, security auditors, and compliance auditors.

Name: PCI SSF 1.2

ID: 184D9BE1-8DE8-4322-92D2-3BDCC9148241

The following is a summary of the application security portions of the Secure Software Requirements and Assessment Procedures defined in the Payment Card Industry (PCI) Software Security Framework (SSF) v1.2. Fortify tests for 44 application security related control objectives across Control Objective sections 2, 3, 4, 5, 6, 7, 8, 10, A.2, B.2, B.3, C.1, C.2, C.3 and C.4 of PCI SSF and reports whether each control objective is In Place or Not In Place to indicate whether requirements are satisfied or not. This report is intended to measure the level of adherence the specific application(s) possess when compared to PCI SSF 1.2 compliance and is not intended to serve as a comprehensive Report on Compliance (ROC). The information contained in this report is targeted at project managers, security auditors, and compliance auditors.

Name: SANS Top 25 2011

ID: 92EB4481-1FD9-4165-8E16-F2DE6CB0BD63

SANS Top 25 2011 Most Dangerous Software Errors provides an enumeration of the most widespread and critical errors, categorized by Common Weakness Enumeration (CWE) identifiers, that lead to serious vulnerabilities in software (<http://cwe.mitre.org/>). These software errors are often easy to find and exploit. The inherent danger in these errors is that they can allow an attacker to completely take over the software, steal data, or prevent the software from working at all.

Name: STIG 5.3

ID: DA04684C-0AC8-44E8-BF65-C6CCD8B369C7

Each requirement or recommendation identified by the Defense Information Systems Agency (DISA) Security Technical Implementation Guide (STIG) is represented by a STIG identifier (STIGID), which corresponds to a checklist item and a severity code [APSC-DV-*ID*: CAT *SEV*]. DISA STIG defines three severities with respect to vulnerabilities where their:

exploitation leads to direct and immediate loss of Confidentiality, Availability, or Integrity (CAT I).

exploitation potentially results in loss of Confidentiality, Availability, or Integrity (CAT II).

existence degrades protections against loss of Confidentiality, Availability, or Integrity (CAT III).

This report is intended to measure the level of adherence the specific application(s) possess when compared to DISA STIG 5.3 compliance and is not intended to serve as a comprehensive Report on Compliance (ROC). The information contained in this report is targeted at project managers, security auditors, and compliance auditors.

The following table summarizes the number of issues identified across the different STIGIDs broken down by Fortify Priority

Order. The status of a STIGID is considered "In Place" when there are no issues reported for a given STIGID.

If the project is missing a Fortify Static Code Analyzer (SCA) scan, or the scan contains findings that have not been fixed, hidden or suppressed, STIGID APSC-DV-003170: CAT II is not considered "In Place". Similarly, if the project is missing a Fortify WebInspect scan, or the scan contains any critical findings, STIGID APSC-DV-001460: CAT II and STIGID APSC-DV-002930: CAT II are not considered "In Place".

Name: STIG 6.1

ID: 0B7007F0-0BBE-4E7B-A73D-8BA4F2B1F678

Each requirement or recommendation identified by the Defense Information Systems Agency (DISA) Security Technical Implementation Guide (STIG) is represented by a STIG identifier (STIGID), which corresponds to a checklist item and a severity code [APSC-DV-*ID*: CAT *SEV*]. DISA STIG defines three severities with respect to vulnerabilities where their:

exploitation leads to direct and immediate loss of Confidentiality, Availability, or Integrity (CAT I).

exploitation potentially results in loss of Confidentiality, Availability, or Integrity (CAT II).

existence degrades protections against loss of Confidentiality, Availability, or Integrity (CAT III).

This report is intended to measure the level of adherence the specific application(s) possess when compared to DISA STIG 6.1 compliance and is not intended to serve as a comprehensive Report on Compliance (ROC). The information contained in this report is targeted at project managers, security auditors, and compliance auditors.

The following table summarizes the number of issues identified across the different STIGIDs broken down by Fortify Priority Order. The status of a STIGID is considered "In Place" when there are no issues reported for a given STIGID.

If the project is missing a Fortify Static Code Analyzer (SCA) scan, or the scan contains findings that have not been fixed, hidden or suppressed, STIGID APSC-DV-003170: CAT II is not considered "In Place". Similarly, if the project is missing a Fortify WebInspect scan, or the scan contains any critical findings, STIGID APSC-DV-001460: CAT II and STIGID APSC-DV-002930: CAT II are not considered "In Place".

Name: STIG 6.2

ID: 79BFB020-3E21-4348-A430-A32EF50B3E1E

Each requirement or recommendation identified by the Defense Information Systems Agency (DISA) Security Technical Implementation Guide (STIG) is represented by a STIG identifier (STIGID), which corresponds to a checklist item and a severity code [APSC-DV-*ID*: CAT *SEV*]. DISA STIG defines three severities with respect to vulnerabilities where their:

exploitation leads to direct and immediate loss of Confidentiality, Availability, or Integrity (CAT I).

exploitation potentially results in loss of Confidentiality, Availability, or Integrity (CAT II).

existence degrades protections against loss of Confidentiality, Availability, or Integrity (CAT III).

This report is intended to measure the level of adherence the specific application(s) possess when compared to DISA STIG 6.2 compliance and is not intended to serve as a comprehensive Report on Compliance (ROC). The information contained in this report is targeted at project managers, security auditors, and compliance auditors.

The following table summarizes the number of issues identified across the different STIGIDs broken down by Fortify Priority Order. The status of a STIGID is considered "In Place" when there are no issues reported for a given STIGID.

If the project is missing a Fortify Static Code Analyzer (SCA) scan, or the scan contains findings that have not been fixed, hidden or suppressed, STIGID APSC-DV-003170: CAT II is not considered "In Place". Similarly, if the project is missing a Fortify WebInspect scan, or the scan contains any critical findings, STIGID APSC-DV-001460: CAT II and STIGID APSC-DV-002930: CAT II are not considered "In Place".

Name: STIG 6.3

ID: 11DF2ABB-D254-4D5D-BC96-2A056EB85CFB

Each requirement or recommendation identified by the Defense Information Systems Agency (DISA) Security Technical Implementation Guide (STIG) for Application Security and Development is represented by a STIG identifier (STIGID), which corresponds to a checklist item and a severity code [APSC-DV-*ID*: CAT *SEV*]. DISA STIG defines three severities with respect to vulnerabilities where their:

- exploitation leads to direct and immediate loss of Confidentiality, Availability, or Integrity (CAT I).
- exploitation potentially results in loss of Confidentiality, Availability, or Integrity (CAT II).
- existence degrades protections against loss of Confidentiality, Availability, or Integrity (CAT III).

This report is intended to measure the level of adherence the specific application(s) possess when compared to DISA STIG 6.3 compliance and is not intended to serve as a comprehensive Report on Compliance (ROC). The information contained in this report is targeted at project managers, security auditors, and compliance auditors.

The following table summarizes the number of issues identified across the different STIGIDs broken down by Fortify Priority Order. The status of a STIGID is considered "In Place" when there are no issues reported for a given STIGID.

If the project is missing a Fortify Static Code Analyzer (SCA) scan, or the scan contains findings that have not been fixed, hidden or suppressed, STIGID APSC-DV-003170: CAT II is not considered "In Place". Similarly, if the project is missing a Fortify WebInspect scan, or the scan contains any critical findings, STIGID APSC-DV-001460: CAT II and STIGID APSC-DV-002930: CAT II are not considered "In Place".

Name: STIG 6.4

ID: 39ABB742-0B5E-4DC5-94DD-975AAD0056CD

Each requirement or recommendation identified by the Defense Information Systems Agency (DISA) Security Technical Implementation Guide (STIG) for Application Security and Development is represented by a STIG identifier (STIGID), which corresponds to a checklist item and a severity code [APSC-DV-*ID*: CAT *SEV*]. DISA STIG defines three severities with respect to vulnerabilities where their:

- exploitation leads to direct and immediate loss of Confidentiality, Availability, or Integrity (CAT I).
- exploitation potentially results in loss of Confidentiality, Availability, or Integrity (CAT II).
- existence degrades protections against loss of Confidentiality, Availability, or Integrity (CAT III).

This report is intended to measure the level of adherence the specific application(s) possess when compared to DISA STIG 6.4 compliance and is not intended to serve as a comprehensive Report on Compliance (ROC). The information contained in this report is targeted at project managers, security auditors, and compliance auditors.

The following table summarizes the number of issues identified across the different STIGIDs broken down by Fortify Priority Order. The status of a STIGID is considered "In Place" when there are no issues reported for a given STIGID.

If the project is missing a Fortify Static Code Analyzer (SCA) scan, or the scan contains findings that have not been fixed, hidden or suppressed, STIGID APSC-DV-003170: CAT II is not considered "In Place". Similarly, if the project is missing a Fortify WebInspect scan, or the scan contains any critical findings, STIGID APSC-DV-001460: CAT II and STIGID APSC-DV-002930: CAT II are not considered "In Place".

Name: SWC

ID: 834F2488-AE1E-4465-8E69-4BA5A54C37D0

The Smart Contract Weakness Classification (SWC) is a systematic framework that categorizes and explains vulnerabilities in smart contracts. It provides a standardized way to understand and address weaknesses in these self-executing code pieces running on blockchains like Ethereum. Notably, the SWC registry's content has not been comprehensively updated since 2020, resulting in known incompleteness, errors, and important omissions.

Name: WASC 2.00

ID: 74f8081d-dd49-49da-880f-6830cebe9777

The Web Application Security Consortium (WASC) was created as a cooperative effort to standardize, clarify, and organize the threats to the security of a web site. Version 2.00 of their Threat Classification outlines the attacks and weaknesses that can commonly lead to a website being compromised.